litellm-pypi-supply-chain-attack

The LiteLLM supply chain attack involved the compromise of the LiteLLM PyPI package, resulting in the distribution of malware versions 1.82.7 and 1.82.8. This allowed attackers to steal credentials and potentially spread to Kubernetes clusters.

REPORT ID
threat-20260325T094311Z-22b3b602b131444c8aed948517ef7dfd

CREATED
2026-03-25

THREAT ACTOR
TeamPCP

CLASSIFICATION
Critical Severity

Executive Summary

The LiteLLM supply chain attack compromised versions 1.82.7 and 1.82.8 of the popular Python package, leading to credential theft and potential lateral movement within compromised systems. Immediate action is required to mitigate the impact.

🎯 Key Findings

- Compromised versions 1.82.7 and 1.82.8 of LiteLLM distributed on PyPI contained credential-stealing malware (Sonatype, 2026).
- The malware targeted SSH keys, API keys, cloud provider credentials, Kubernetes configurations, and cryptocurrency wallet data (GIGAZINE, 2026; Sonatype, 2026).
- Attackers attempted lateral movement in Kubernetes environments by creating privileged pods and installing persistent backdoors (FUTURESEARCH, 2026; Sonatype, 2026).
- The attack was linked to TeamPCP, a threat actor involved in a broader supply chain campaign (DreamFactory, 2026; Sonatype, 2026).

📊 Campaign Overview

Campaign Details

Name: LiteLLM Supply Chain Attack

Duration: March 2026

Primary Targets:

Developers using LiteLLM | CI/CD pipelines | Cloud environments | Kubernetes clusters

Attack Vector:

A coordinated supply chain attack targeting the LiteLLM package on PyPI to steal credentials and gain unauthorized access to systems and cloud environments.

👤 Threat Actor Attribution

TeamPCP

Motivation: Credential theft, unauthorized access, lateral movement, persistent access

Techniques:

- Compromising CI/CD pipelines
- Injecting malicious code into packages
- Exploiting .pth files
- Lateral movement in Kubernetes environments

🔍 Tactics, Techniques & Procedures (TTPs)

MITRE ATT&CK Framework

Initial Access | Execution | Persistence | Credential Access | Discovery | Lateral Movement | Collection | Exfiltration | Impact

Specific Techniques

```
T1195 - Supply Chain Compromise
```

```
T1059 - Command and Scripting Interpreter
```

```
T1543 - Create or Modify System Process
```

```
T1003 - OS Credential Dumping
```

```
T1082 - System Information Discovery
```

```
T1021 - Remote Services
```

```
T1119 - Automated Collection
```

```
T1041 - Exfiltration Over C2 Channel
```

🎯 Attack Process & Kill Chain Analysis

Attack Methodology

The attack involved multiple stages, starting with the compromise of CI/CD pipelines, followed by the injection of malicious code into the LiteLLM package, credential theft, and attempts at lateral movement and persistence.

Cyber Kill Chain Phases

- Initial Access
- Execution
- Installation
- Command & Control
- Actions on Objectives

Attack Flow & Sequence

1. Compromise of CI/CD pipeline
2. Injection of malicious code into LiteLLM
3. Distribution of compromised package via PyPI
4. Execution of malicious code on target systems
5. Credential theft
6. Lateral movement in Kubernetes environments
7. Persistence via systemd services

Initial Entry Points

- Compromised CI/CD pipeline
- Malicious .pth file
- Obfuscated payload in proxy_server.py

Lateral Movement Steps

- Exploitation of Kubernetes service account tokens
- Creation of privileged pods

- Mounting host filesystems

Persistence Mechanisms

Systemd user service

Malicious .pth file

Data Exfiltration Methods

Data compression into tpcp.tar.gz

Encryption using AES-256-CBC and RSA

POST requests to models.litellm.cloud

🦠 Malware Analysis

Malware Families

Credential Stealer

Backdoor

The malware functions as a multi-stage credential stealer and dropper. It harvests sensitive files, encrypts and exfiltrates data, and establishes persistence for ongoing remote control. The malware also attempts lateral movement in Kubernetes environments.

🌍 Impact Assessment

Affected Sectors

Technology | Finance | Healthcare | AI Research | Software Development

Geographic Impact

The attack has implications for organizations that rely on LiteLLM for managing AI models. Any sector utilizing AI, such as finance, healthcare, and technology, could be affected. The geopolitical impact is minimal.

🌌 Dark Web Intelligence

No specific dark web intelligence was mentioned in the provided articles.

Findings

No specific dark web intelligence was mentioned in the provided articles.

🔍 Vulnerabilities

The primary vulnerability exploited was the lack of proper supply chain security measures, allowing malicious code to be injected into the LiteLLM package. The use of .pth files as an execution vector was also a key vulnerability.

Affected Products

LiteLLM versions 1.82.7 and 1.82.8

🔍 Threat Landscape

The threat landscape shows an increasing trend of supply chain attacks targeting widely used packages in AI ecosystems. Attackers are focusing on high-value targets to gain access to sensitive data and credentials.

Top Threats

- Supply chain attacks targeting AI-related packages
- Credential theft leading to unauthorized access
- Lateral movement and persistence in cloud environments

Trends

- Increased sophistication of supply chain attacks
- Targeting of credentials for multiple AI service providers
- Use of automated tools for detecting and blocking malicious packages

Mitigation Recommendations

- ✓ Remove compromised versions of LiteLLM (1.82.7 and 1.82.8) (FUTURESEARCH, 2026).
- ✓ Rotate all potentially exposed credentials (FUTURESEARCH, 2026; Sonatype, 2026).
- ✓ Investigate affected systems for persistence mechanisms and unauthorized access (Sonatype, 2026).
- ✓ Pin all dependency versions in requirements.txt and lockfiles (DreamFactory, 2026).
- ✓ Use hash verification for critical dependencies (DreamFactory, 2026).
- ✓ Separate CI/CD concerns and implement egress filtering (DreamFactory, 2026).
- ✓ Monitor for .pth files in Python site-packages directories (DreamFactory, 2026).

🔗 Supply Chain Risk

Affected Partners

Aqua Security (Trivy)

Checkmarx

> Compromised CI/CD pipelines of Aqua Security and Checkmarx led to the compromise of LiteLLM, highlighting the risk of transitive dependencies and the importance of securing the software supply chain.

🔗 References

https://forums.developer.nvidia.com/t/critical-attack-litellm-compromised-pin1-82-6-now/364638

https://gigazine.net/news/20260325-litellm-supply-chain-attack/

https://www.sonatype.com/blog/compromised-litellm-pypi-package-delivers-multi-stage-credential-stealer

https://futuresearch.ai/blog/litellm-pypi-supply-chain-attack/

https://blog.dreamfactory.com/the-litellm-supply-chain-attack-a-complete-technical-breakdown-of-what-happened-who-is-affected-and-what-comes-next

© Transilience – All rights reserved.

Contact: **hello@transilience.ai** | Website: **https://transilience.ai**